



Blind Search



Bối cảnh (Context)

Kho lưu trữ dữ liệu của cục tình báo có một thanh tìm kiếm tài liệu chuyên dụng. Giao diện trang web được thiết kế cực kỳ tối giản: nếu bạn tìm thấy kết quả, trang sẽ hiện chữ "Found". Nếu không, trang hiện "Not Found". Không có bất kỳ lỗi SQL nào được in ra màn hình, cũng không có dữ liệu thật nào hiển thị.

Nhưng một điệp viên đã tuyên bố rằng anh ta có thể trích xuất được toàn bộ dữ liệu từ thanh tìm kiếm này chỉ bằng cách kiên nhẫn quan sát và đặt câu hỏi Đúng/Sai.



Mục tiêu (Objective)

- **Nhiệm vụ:** Trích xuất Flag đang nằm trong cơ sở dữ liệu.
- **Vấn đề / Lỗi hổng: Blind SQL Injection (Boolean-based).** Mặc dù không in ra dữ liệu, câu truy vấn SQL vẫn bị thao túng. Người chơi có thể chèn các câu lệnh điều kiện (ví dụ: kí tự đầu tiên của Flag có phải là 'A' không?) và quan sát kết quả trang web phản hồi (Found hay Not Found) để suy luận ra từng ký tự của Flag.
- **Flag:** Tìm từng ký tự của Flag trong bảng dữ liệu bí mật.



Gợi ý (Hints)

- Cấu trúc truy vấn cơ bản: `search_term' AND (SELECT SUBSTRING(flag,1,1) FROM flags) = 'A' -- -`
- Nếu trang web trả về Found, nghĩa là ký tự đầu tiên là 'A'. Lặp lại quá trình này với các ký tự tiếp theo.
- Sử dụng công cụ `sqlmap` có thể giúp bạn tự động hóa việc này.